

5.0 Incident Response

5.1 BENEFITS OF INCIDENT MANAGEMENT SYSTEM

The formation of an Incident Management System will provide Shameless with a set of procedures to follow in the event of a computer security incident. A consistent and detailed Incident Management System will assist personnel to minimize loss or theft of information and disruption of services caused by incidents. As previous sections of this ISMS have detailed, the loss, theft, and disruption of information and services may cause great financial consequences to the organization. To minimize financial and data loss, the Incident Management System has been designed to allow for constant updates, in order to tackle new threats as they arise. In this manner, the organization's defenses against computer-related attacks are further reinforced and improved upon.

The Incident Management System facilitates the response to computer security incidents in a number of ways. Perhaps the most important, it defines what exactly an incident is, and dictates methods to both detect incidents, and confirm their verity. Depending on the incident, methods of containment, data recovery, and evidence retrieval and handling procedures are detailed. The collection of evidence allows for the prosecution of malicious actors, preventing them from orchestrating further exploitation of computer systems and disruption to the organization's business processes. In addition to procedural instructions, the Incident Management System encourages reflection upon its own capacity to adequately address computer security incidents. If deficiencies are found in the processes outlined in the Incident Management System, the high-level management of Shameless, equipped with the counsel of IT Department Managers, are encouraged to revise or replace policies in order to improve the organization's security environment.

5.2 APPROACHES TO INCIDENT MANAGEMENT SYSTEM

5.2.1 CMU INCIDENT RESPONSE PLAN

The Carnegie Mellon University Incident Response Plan utilizes a six step process in order to organize the identification and response to a computer security incident. The steps are as follows: preparation, detection, containment, investigation, remediation, recovery. The CMU IRP defines events, incidents, and references the ISO for data classification schemas. The CMU IRP is a very general template, dictating what an organization's Incident Management System should accomplish, but does not necessarily discuss the best or recommended practices to achieve such an end.

5.2.2 NIST SPECIAL PUBLICATION 800-61 REVISION 2

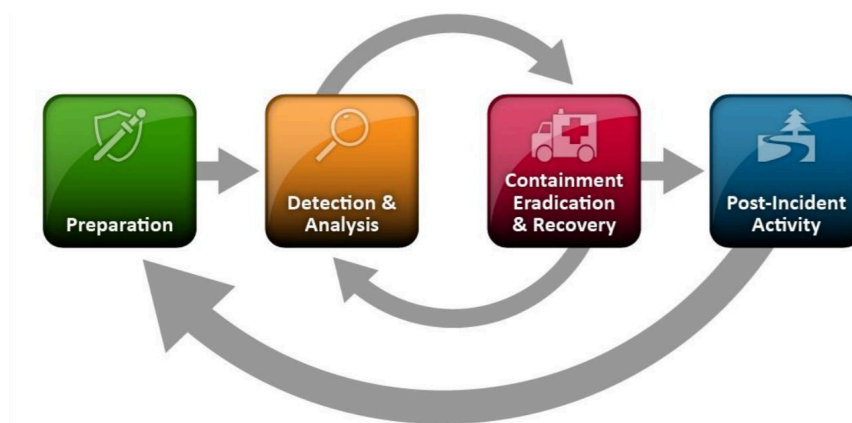
The NIST framework combines individual steps mentioned in both the CMU Incident Response Plan, and SANS Incident Response Framework, into a four step procedure. Those steps are as follows: (1) Preparation, (2) Detection and Analysis, (3) Containment, Eradication and Recovery, (4) Post-Incident Activity. NIST provides detailed yet general instructions for the formation of a highly-functioning and modifiable Incident Management System. This is represented through NIST's inclusion of various sub topics such as Incident Prioritization, Identification of Attacking Hosts, and Using Collected Incident Data, all of which come together to provide a clear, detailed, and linear system to follow in the event of a computer security process.

5.2.3 SANS INCIDENT RESPONSE FRAMEWORK

The SANS Framework is, similar to the CMU IRP, a six step procedure that outlines the various stages responding to a computer security incident. The level of detail it presents is somewhere between the CMU and NIST frameworks. What is particularly useful are the "cheat sheets" SANS provides. These include useful command line prompts in both Windows and Linux, to see various processes and their associated services: additionally, a checklist is included to neatly summarize all sections of the framework.

5.2.4 RECOMMENDED APPROACH

It is recommended that Shameless utilizes the system established by NIST SP 800-61 Revision 2. There are multiple reasons for this recommendation. Firstly, the number of staff available to respond to computer security incidents is minimal. For this reason, NIST is particularly appealing, due to the fact that it envelops the detection and analysis procedures, as well the containment, eradication and recovery sections, into two steps respectively. The conjunction of these steps enables the small number of responders (called a CPMT, see Section 7.3) to be more efficient, handling one task at a time in all its entirety, rather than handling or revisiting multiple tasks, all at different stages in the Incident Response Lifecycle. A graphic of the Incident Response Lifecycle as determined by NIST is included below:



**Figure 8. Incident Response Life Cycle
(NIST SP 800-61r2)**

Both the NIST and SANS frameworks for Incident Response acknowledge that, sometimes, it is necessary to revise previously determined processes or procedures in order to confront a new issue. For example, the recovery of a device affected by a virus may lead to the detection of a different form of malware on that device, a keylogger!

5.3 PRE-INCIDENT PREPARATION

5.3.1 INCIDENT DEFINITION

A business network is constantly undergoing many different processes and services. According to the NIST SP 800-61 Revision 2, “any observable occurrence” in a system can be defined as an event. This includes anything from a server receiving a web page request to a user sending out an email. On the other hand, an incident is defined as “a violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices.” For example, this could be when an attacker obtains sensitive data or if malware gets installed. These two definitions must be understood and differentiated to allow for proper focus in order to minimize downtime and loss.

5.3.2 INCIDENT CLASSIFICATION

5.3.2.1 IMPACT ON CIA

A guiding model to understanding cybersecurity measures is the CIA triad. Confidentiality represents the protection of assets from unauthorized access. Integrity ensures that all data is trustworthy while being complete and unaltered. Availability means that data and services are accessible when they need to be.

When an incident compromises even one of these categories, business operations could be halted and Shameless can experience serious financial losses due to downtime or applicable fines. Our incident response plan ensures that these violations will be minimized with an emphasis on timely remediation.

5.3.2.2 CLASSIFICATION SCHEME

Following the classification scheme provided by NIST SP 800-61 Revision 2, incidents will be divided into categories based on impact. This will allow for the prompt allocation of necessary resources, efficiently delegating tasks in order for Shameless to continuously operate. Below is a table that defines how incidents are differentiated:

Category	Definition
None	No effect to the organization's ability to provide all services to all users
Low	Minimal effect; the organization can still provide all critical services to all users but has lost efficiency
Medium	Organization has lost the ability to provide a critical service to a subset of system users
High	Organization is no longer able to provide some critical services to any users

Figure 9. Functional Impact Categories (NIST SP 800-61r2)

5.3.3 INCIDENT HANDLING

Based on which category an incident falls under, tasks to resolve the issue will be delegated to necessary departments. All potential incidents should always be reported to the Help Desk. Here, the incident will be reviewed and determined to be invalid or valid. In the case the incident falls in the “none” category, it will be reported and placed into archival. If the incident is determined to be of “low impact”, the Help Desk will resolve the issue. In the case of a “medium impact” incident, the Help Desk will work towards a resolution with the aid of the CPMT if needed. For any “high impact” incidents, the task will be delegated and handled entirely by the CPMT to ensure maximum efforts. Below is a working flow chart outlining the incident handling process:

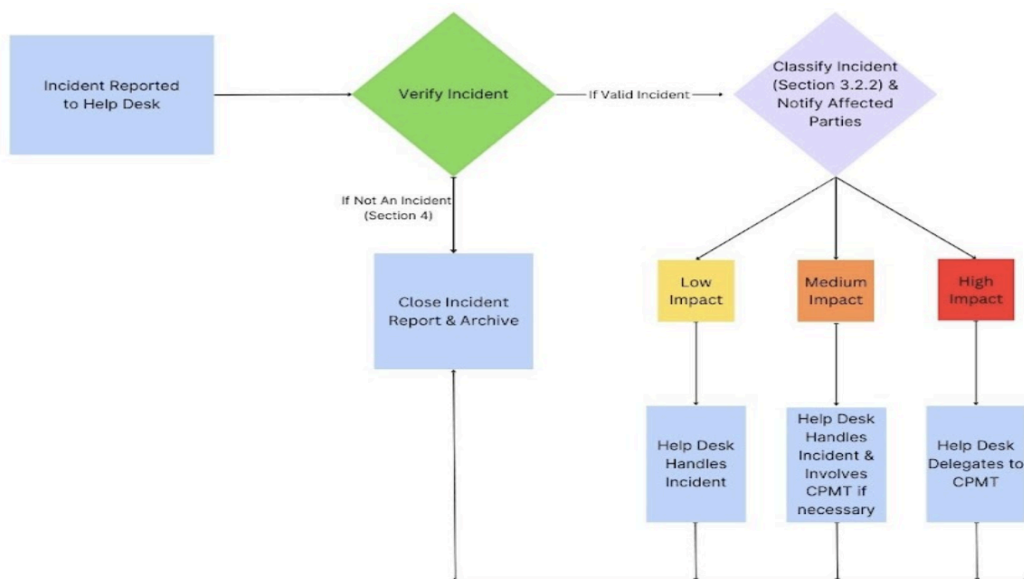


Figure 10. Incident Handling Flow Diagram

5.3.4 EXAMPLE APPLICATION

5.3.4.1 DETECTION AND ANALYSIS

Consider the incident in which 1,000 of Shameless client's had their data leaked on Reddit. At first detection, a report should be filed with the Help Desk. Qualified and pertinent employees on the CPMT (in this case, the DPO and CTO) should analyze the legitimacy of the event (in this case, leaked data). Upon finding that the leaked information is legitimate, the incident enters the containment, eradication, and recovery stage.

5.3.4.2 CONTAINMENT, ERADICATION, RECOVERY

In this stage, the CPMT must "fix" the issue. While the breach of personally identifiable information (PII) cannot be undone, steps can be taken to limit the potential of further breaches. For example, the situation can be contained by changing passwords to prevent further unauthorized access to PII. This can be achieved through the Active Directory server by someone with an administrator account, such as the Network Manager or CTO. To recover from the breach, Shameless must also notify the affected individuals whose data was leaked. This action is required by regulatory bodies such as the GDPR and CPRA.

5.3.4.3 POST-INCIDENT ACTIVITY

This phase includes a follow-up investigation/incident report, conducted by the CPMT. The incident report requires a holistic understanding of the potential causes of the data leak. Staff at Shameless did execute this step, which revealed useful information about policies at the organization. The investigation found that a third party support technician's email account was brute forced. This suggests that Shameless may need to consider a policy which only allows contracting with organizations that have respectable and transparent security policies. The report continues, stating that the database administrator's password was stolen. Additionally, this password was only 5 characters in length, and used for multiple logins. This fact suggests the necessity for password training, and the creation and strict enforcement of a password policy, which includes stipulations on password length, character diversity, as well as unique passwords for each login page.

5.3.4.4 PREPARATION

The solutions revealed by the above investigation must be implemented in order to protect the organization from related incidents. Because the post-incident investigation revealed deficiencies in training and policy, the CPMT should work closely with the HR manager to implement adequate training and update or create policies accordingly. If the post-incident investigation revealed deficiencies in networking hardware, such as routers or firewalls, the CPMT should work closely with the Network Manager to remedy vulnerabilities.

5.4 IDENTIFYING AND REPORTING

There are numerous methods that can be used to successfully identify and report potential signs of an incident. These signs can fall into two categories: precursors and indicators. A precursor shows that an incident may occur in the future. An indicator shows that an incident did in fact occur or is currently occurring. Precursors are much less common than indicators, but the event of detection can help prepare or at least allow more activity monitoring involving the perceived target. Indicators are much more common and can include events from suspicious login attempts to deviations in network traffic flows. It is the responsibility of the Help Desk to properly identify each incident into these categories for proper allocation of time and resources. Below are different sources that can be used to help with these efforts:

5.4.1 SECURITY FORUMS

A local security forum can be created to allow for quick and efficient communication between employees and the Help Desk. If an employee detects suspicious activity in the network or on their system, they can immediately alert the Help Desk through this forum. Different categories can be created to facilitate and organize potential incidents, allowing for streamlined processes and timely remediation. Furthermore, the forum can include industry discoveries and recommendations regarding specific issues. However, this can be overwhelming and potentially cause delays depending on the amount of tickets coming through.

5.4.2 INTRUSION DETECTION SYSTEM (IDS)

An IDS deployed throughout the Shameless network will continuously monitor for suspicious activity and potential security breaches, recording important data regarding them. This includes time of event, relevant IP addresses, type of attack, etc. These records should always be stored and backed-up in case of an actual attack to allow for proper evaluation and prevention in the future. This system will provide large amounts of data, but can be hard to decipher and organize.

5.4.3 SECURITY INCIDENT AND EVENT MANAGEMENT (SIEM)

Similar to an IDS, a SIEM records important data regarding suspicious activity and potential security breaches. However, it can analyze and aggregate large chunks of data and logs, making it much more practical from a user perspective. Compliance and user-behavior can also be recorded, allowing for in-depth recommendations. It can be altered in order to be more applicable to the specific needs of Shameless. Alerts can be sent to the Help Desk based on calculated risk formulas that determine the potential of an incident. Compared to an IDS, this provides a less overwhelming workload on employees with a user-friendly interface, efficiently allowing for proper identification and remediation efforts. For a company with Shameless' size and budget, we recommend beginning with the service provided by Grafana Cloud. It begins as free and cost increases based on demand by Shameless. Depending on the needs of the company, IBM's QRadar SIEM can also be implemented. Pricing is around ~\$550 per month, but provides all functionalities available by a SIEM as it is an industry-leading product.

5.4.4 DISASTER INCIDENT

An incident can be defined as a disaster if the company can't contain/control it's impact or if the damage is so severe that the company can't recover in a timely fashion. A

Disaster Recovery Team (DRT) should be developed in the case that this occurs. It will include knowledgeable employees that are capable of understanding and handling this stressful situation. For Shameless, this will likely involve the Network Manager, the Data Protection Officer, and Help Desk Operatives, at the least. The main goal of the DRT is to reestablish operations from the impacted location. Natural and human-made disasters must be differentiated to allow proper resource management. Furthermore, it should be known whether the disaster occurred rapidly or slowly. A rapid disaster is difficult to prepare for, but having knowledge about a slow-onset disaster can prevent future incidents of the same nature.

5.4.5 LAW ENFORCEMENT INVOLVEMENT

The CPMT and DRT should become acquainted with relevant law enforcement representatives and develop a line of communication in the event of an incident that violates civil or criminal law. The conditions of when to report an incident, how to report an incident, and proper evidence handling should all be discussed and established beforehand. NIST recommends that a designated individual shall be assigned as the primary point-of-contact between the company and law enforcement. For Shameless, the Data Protection Officer will likely be that line of communication. However, it should be noted that the alert of law enforcement will likely lead to public knowledge of the incident. This can harm company reputation and should be resorted to only when necessary.

5.5 PERFORMANCE METRICS AND INCIDENT RESPONSE LIFECYCLE

Performance metrics are useful for the assessment of company performance, which leads nicely to finding which areas need the most attention. ISO 27001 recommends keeping track of KPIs, or Key Performance Indicators. KPIs allow a quick and efficient way to communicate the importance and current landscape of security for management at Shameless, and thus are important in keeping the organization secure in the future.

5.5.1 KEY PERFORMANCE INDICATORS (KPIs)

KPIs include data about security, such as: Number of vulnerabilities addressed within a month of their discovery, Number of security events in the last month, Length of time between incident and detection, Percentage of assets that have had a cost benefit analysis performed for, etc. KPIs are important to analyze, and taking them into account will help Shameless align with clause 9.1 of ISO 27001. To continually analyze and address metrics/KPIs, we recommend that Shameless employ Servicenow's ITSM product. ITSM tools facilitate a healthy workplace environment, as they offer an all-in-one solution to

facilitating tasks and operating workflows. ITSM can assist with asset management, change management, config management, continual improvement management, incident response, and management of knowledge. Essentially, an ITSM provides a general location for requests to be handled and for incidents to be dealt with. We also recommend the use of Snort, a Linux open-source IDS (Intrusion Detection System) and IPS (Intrusion Prevention System). Snort also provides real-time network traffic analysis, which is useful for logging. Networking tools such as Snort or alternatives like Suricata allow Shameless to monitor who enters the network, along with preventing/ detecting data exfiltration. In the case of a DDoS, Snort can identify the attack and be configured to automatically block such attempts to bring down the network. In the case of a worm, Snort can be used to detect and stop the attack from propagating through the system.

5.6 INCIDENT DOCUMENTATION

Incidents can be documented using ITSM and Snort. Reference section 3.4 for more information on how incidents could be documented. As listed in section 2, we foremost recommend the use of the NIST SP 800-61 Revision 2 framework, and thus believe that incidents should be documented in accordance with the framework.

5.6.1 NIST RECOMMENDATIONS

NIST recommends that an issue tracking database be used to keep track of all information related to incidents, including a chain of custody document for evidence and audio logs for completeness. NIST recommends the use of either a logbook or digital camera and audio recorder. We recommend that Shameless employ the digital camera to record evidence of incidents.

5.7 DISASTER RECOVERY PLAN

5.7.1 BACKUPS AND 123 RULE

The disaster recovery plan will focus on implementing backup strategies, particularly adhering to the 3-2-1 rule, to mitigate risks and ensure business continuity in the event of data loss or disaster. The 3-2-1 rule is a widely-recognized industry standard for data backup and recovery. It includes maintaining at least three copies of data, storing these copies on at least two different types of storage media, and keeping at least one copy off the physical company site in the case of natural disaster.

The backup strategy plan will include steps for infrastructure setup, data classification, backup frequency, storage media, offsite backup, backup testing, and maintenance

procedures. A centralized backup infrastructure will be established in the company that consists of hardware and software solutions such as adequate backup servers and network infrastructure. These should include encryption mechanisms that will secure the data being held.

Next, data will be classified based on its criticality business operations, and backed up according to its ranking. Backup frequency will then be determined by the level of critical data in the business, and the rate of data change. Incremental backups should be conducted daily or multiple times a day depending on the level of data criticality, and full backups are recommended to be conducted every month. These backups should then be stored in a combination of storage media such as disks, drives, and cloud storage onsite to create redundancy of data in case one medium fails or becomes corrupted, and a secure offsite backup location that is geographically distant from the primary site should store another copy of all the data backed up at the primary site. This can include the company sites in India and USA that are besides the main office site in the UK.

These backup sites should be regularly tested in its backup and recovery procedures to ensure their reliability in protecting the data. Simulated disaster scenarios are recommended to be conducted in order to validate the effectiveness of the disaster recovery plan. Finally, continual routine maintenance checks should be conducted at the main office site including software and hard checks to ensure the health of company systems and backup processes.

5.7.2 SOFTWARE RECOMMENDATIONS

Software Function	Software Names	Software Description
Backup & Recovery Solution	Veeam Backup & Replication or Commvault Complete Backup & Recovery	Provides comprehensive data protection by creating backup copies of critical data and applications. Offers features such as encryption and flexible recovery options to minimize data loss and downtime during disaster recovery scenarios.
Cloud Disaster Recovery Service	Azure Site Recovery or AWS Disaster Recovery	Enable replication of workloads and data to the cloud for rapid recovery in the event of on-premises failures or disasters. They

		offer automated failover, scalability, and cost-effective disaster recovery solutions.
Data Replication Software	Zerto or VMware vSphere Replication	Replicates data in real-time or near-real-time between multiple locations or data centers. Ensures data availability and resiliency by maintaining synchronized copies of critical data across geographically dispersed sites.
Server Virtualization Platform	VMware vSphere or Microsoft Hyper-V	Enable consolidation of server workloads, improves resource utilization, and facilitates rapid provisioning of virtual machines during disaster recovery scenarios. They offer features such as high availability and live migration to enhance workload mobility and resilience.
Network and Application Monitoring Tool	SolarWinds Network Performance Monitor or Nagios Core	Provides real-time visibility into network infrastructure and application performance. Detects anomalies, identifies potential issues, and facilitates proactive incident response to minimize service disruptions and downtime.
Incident Response Management System	ServiceNow Security Incident Response or IBM Resilient	Provides centralized platforms for managing security incidents from detection through resolution. Facilitates collaboration among incident response teams, tracks incident progress, and ensures timely remediation.
Communication and Collaboration Platform	Slack or Microsoft Teams	Facilitates real-time communication and

		information sharing among disaster recovery and incident response teams. Enables rapid decision-making, coordination of response efforts, and documentation of incident details.
Business Continuity Planning Software	BCP Builder or Assurance Software	Helps organizations develop and maintain comprehensive business continuity plans. Provides templates, workflows, and risk assessment tools to streamline the business continuity planning process and ensure readiness for disaster recovery scenarios.

Figure 11. Software Recommendations and Purposes

5.8 CPMT ESTABLISHMENT

Below is a flow-chart representing the Contingency Planning Management Team:

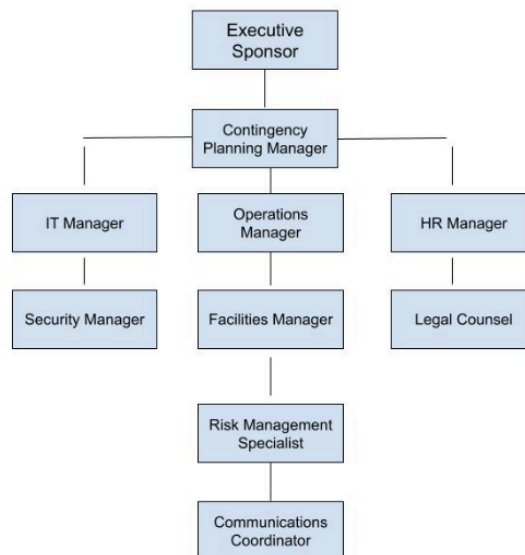


Figure 12. CPMT Flow-Chart

5.8.1 DECISION MAKERS

All members in a team highlighted in the flow chart above must work together to find solutions that are acceptable to everyone involved. Decisions are informed by the expertise and knowledge of individual team members. Each member brings a unique perspective and skill set to the table, contributing valuable insights to the decision-making process. Individual role descriptions are illustrated below:

Executive Sponsor: This individual provides overall strategic direction, support, and resources for the disaster recovery plan. They are typically a high-level executive responsible for ensuring that the plan aligns with business objectives and priorities.

Contingency Planning Manager: This person is responsible for overseeing the development, implementation, and maintenance of the disaster recovery plan. They coordinate the activities of various stakeholders and ensure that the plan is comprehensive and effective.

IT Manager, Operations Manager, HR Manager, Security Manager, Facilities Manager, Legal Counsel: These departmental managers are responsible for providing expertise and support in their respective areas. They contribute to the development of contingency plans specific to their departments and ensure alignment with overall organizational goals.

Risk Management Specialist: This individual assesses potential risks and threats to the organization and develops mitigation strategies to address them. They provide input on risk assessment and risk management strategies within the context of the disaster recovery plan.

Communications Coordinator: This person is responsible for coordinating internal and external communications during a disaster or emergency situation. They ensure that stakeholders are kept informed and updated on the status of recovery efforts.

5.9 POTENTIAL UPDATES TO INCIDENT RESPONSE LIFECYCLE

During the investigation phase of the incident response life cycle, the primary objective is to gather information, analyze data, and determine the scope and severity of the incident. An incident response team should be delegated by the company to come into action upon detection of an incident. They will assess the situation and prioritize response efforts based on the potential impact on critical systems and data. Relevant evidence, including log files, network traffic captures, system snapshots, and any other pertinent data, is collected to aid in the investigation process. Forensic techniques and tools will be utilized in the investigation process by

professionals to analyze the collected evidence, identify indicators of compromise, and uncover the root cause of the incident. Finally, effective communication between all members of the incident response team and other relevant parties such as stakeholders are crucial to ensure a cohesive and efficient response effort throughout the investigation phase.

As cyber threats continue to evolve and become more sophisticated, it is essential to regularly review and update the incident response life cycle as depicted above to adapt to emerging challenges and improve response capabilities. Conducting regular incident simulation exercises and providing ongoing training to incident response team members can help improve preparedness, response times, and decision-making skills in real-world scenarios; and keep each member up to date of the latest updates to the cycle. Regularly evaluating incident response processes, procedures, and tools, and incorporating lessons learned from past incidents will help team members and the company optimize their incident response program.